

FDE FIELD NOTES · ISSUE 03 OF 10

When security says no to the model.

Treat it as a requirements document, not a blocker.

03

AR

Akhilesh Ranjan Singh

Senior DevSecOps Engineer · github.com/iarsingh

Swipe →

What security actually asks

01 Where does data go?

Every hop, every region, every vendor.

02 Who can see prompts?

Operators, vendors, logs, support staff.

03 How long is it kept?

Retention for prompts, outputs and traces.

04 How do we turn it off?

A kill switch that does not need a deploy.

Egress-safe design

- 1 Local redaction
- 2 Allow-listed endpoint
- 3 No retention
- 4 Audit log
- 5 Kill switch

If even this is not acceptable, a rules engine or a local model is the answer. Sometimes the right model is no model.

Access by role

ROLE	SEES	NEVER SEES
Operator	Own queue + suggestion	Other sites
Engineer	Metrics, hashes	Raw records
Vendor	Nothing by default	Prompts, outputs
Auditor	Decision log	Free-text bodies



What I bring to the review

- ☒ One-page data-flow diagram

- ☒ Egress allow-list

- ☒ Threat model with mitigations

- ☒ Retention and deletion plan

- ☒ Rollback and kill switch

- ☒ Who owns the risk

REFRAME

“No” is the first draft of the requirements.

Ask which condition would make it a yes, then design to that condition.



KEY TAKEAWAY

Show where the data goes before you ask for approval.

- Lead with the data flow
- Redact locally, allow-list egress
- A kill switch that needs no deploy

YOUR TURN

What finally got your security team to say yes — or did it never happen?

FOLLOW AKHILESH RANJAN SINGH

Next in the series: #04 Do not invent the ROI

Save · Repost

